

The WSP Validation Engine — Technical Blueprint

Version: 1.1 · **Date:** 2026-08-20 · **Status:** Research/architecture blueprint (no application code)

What this covers: one component of the ControlIQ platform — the WSP Validation Engine.

ControlIQ is the multi-tenant EU compliance SaaS for Crypto-Asset Service Providers, made of a Firm Application and a Platform Admin Portal, and spanning firm onboarding, the compliance test library, test execution, evidence collection, findings and remediation, reporting and dashboards. This blueprint specifies only the engine that powers ControlIQ's **WSP module** (PRD §6, FR-30–FR-37): a firm uploads ONE document — its **WSP (Written Supervisory Procedures manual)** — and the engine continuously validates it against **MiCA (Regulation (EU) 2023/1114)** and **DORA (Regulation (EU) 2022/2554)**, returning evidence-backed, severity-graded findings and re-validating incrementally when regulations change. The surrounding platform owns what happens next: sign-off, remediation, alerting surfaces, reports.

Claim labels used throughout (and in every linked detail document): **VERIFIED FACT** · **ARCHITECTURAL RECOMMENDATION** · **ASSUMPTION** · **OPEN QUESTION** · **REQUIRES LEGAL / COMPLIANCE INTERPRETATION**. All regulatory claims cite official sources (EUR-Lex, ESMA, EBA, European Commission) with access date 2026-08-17; the full register is in §34.

Authority hierarchy (non-negotiable design rule): **Official Regulation → Requirement → Control → Expected Evidence → WSP evidence**. The two sample WSPs in this folder (**Sample WSP.pdf** , **WSP Sample.pdf**) sit at the *bottom* of that chain — they are structural test cases only, never regulatory authority, and their content is treated as **untrusted data** (prompt-injection surface). Neither sample was modified during this research.

Detail documents this blueprint synthesizes (read them for evidence; this document stands alone at the decision level):

AREA	FILES
Regulatory	regulatory/wsp-meaning.md · regulatory/wsp-mica-analysis.md · regulatory/wsp-dora-analysis.md · regulatory/control-model.md · regulatory/regulatory-ingestion.md
Sample analysis	wsp-analysis/notes-sample-wsp-1.md · wsp-analysis/notes-sample-wsp-2.md · wsp-analysis/sample-wsp-comparison.md · wsp-analysis/sample-wsp-structure.md · wsp-analysis/sample-wsp-consistency-analysis.md · wsp-analysis/sample-wsp-control-mapping.md · wsp-analysis/sample-wsp-extraction-analysis.md · wsp-analysis/sample-wsp-rag-analysis.md
AI / Security	ai/rag-architecture.md · security/llm-security-governance.md · security/security-architecture.md
Architecture	architecture/data-and-events.md · architecture/incremental-revalidation.md · architecture/cost-model.md · diagrams: overall-architecture.mmd, wsp-processing.mmd, regulatory-ingestion.mmd, regulatory-revalidation.mmd, compliance-evaluation.mmd, rag-llm-flow.mmd, database-er.mmd, event-driven.mmd, end-to-end-sequence.mmd, finding-lifecycle.mmd
Market	market/competitor-analysis.md

1. Executive Summary

What this engine is. The validation core behind ControlIQ's WSP module. Given a firm profile and an uploaded WSP version — a 150–200-page internal compliance/supervision manual — it returns, continuously: (1) candidate WSP-section → requirement mappings for the firm's compliance officer to confirm (FR-31), with two-person sign-off handled by the platform (FR-32/33); (2) severity-graded gap and contradiction findings, each citing exact page/section evidence in both the WSP and the regulation, feeding the real-time gap analysis of FR-34; (3) change signals when MiCA/DORA level-1 text, delegated acts (RTS/ITS), or ESMA/EBA guidance moves, flagging exactly the mapped sections that need review (FR-35); and (4) automatic, *incremental* re-validation of only the affected findings across pinned WSP versions (FR-37).

Engine boundary (what this blueprint does and does not own). **Owned here:** WSP ingestion and extraction, section/chunk modelling, the MiCA+DORA control library and its regulatory ingestion/change detection, the applicability engine, the three-layer evaluation engine and its RAG/LLM stack, cross-section consistency, incremental re-validation, the finding/evidence model, compliance scoring, and the rules that decide *when* an alert is warranted. **Consumed from the platform, not rebuilt:** authentication, the eight system roles and RBAC, the two-person sign-off

workflow, remediation tracking, compliance test execution and evidence collection, formal report generation, the firm dashboard shell, onboarding and billing. **Interfaces:** the engine reads the firm profile captured at onboarding and each stored WSP version; it writes findings, evidence spans, scores and change signals that the Firm Application renders and routes; its regulatory ingestion feeds the Platform Admin Portal's regulation publishing flow (PRD §4.5). Sections 18–20 (scoring, alerting, dashboard) and 26–27 (multi-tenancy, cost) are therefore stated as engine *contributions* to platform-level surfaces, not as standalone product features.

The one terminology trap, resolved. "WSP" is a **US FINRA term** (Written Supervisory Procedures, FINRA Rule 3110(b)) — not defined anywhere in EU law, and **not** a MiCA "crypto-asset white paper". Both samples analysed here are US FINRA broker-dealer manuals. ControlIQ transplants the document *genre* into the EU: the WSP is treated as the firm's consolidated policies-and-procedures artefact, validated against the distributed documentation obligations of MiCA Title V/VI and DORA. Every FINRA → EU mapping is interpretive: **REQUIRES LEGAL / COMPLIANCE INTERPRETATION** (§2).

Regulatory state (2026-08-17, all **VERIFIED).** MiCA fully applicable since 30 Dec 2024; DORA since 17 Jan 2025; MiCA CASP grandfathering ended at the latest 1 Jul 2026 — every operating EU CASP should now be authorised and DORA-scoped. The Level-2 layer is now substantially in force (complaints RTS 2025/294, authorisation RTS/ITS 2025/305–306, conflicts 2025/1142, record-keeping 2025/1140, market-abuse 2025/885; DORA RTS 2024/1772–1774, incident reporting 2025/301–302, RoI ITS 2024/2956, TLPT 2025/1190). This is the moment a curated, versioned MiCA+DORA control library becomes both feasible and valuable (§4).

The core deliverables of this research. - A **39-control seed library**: 24 MiCA controls (MICA-WSP-001...024) + 15 DORA controls (DORA-WSP-001...015), each with article anchor, applicability, severity, validation type (deterministic/semantic/hybrid), and expected evidence (§5, §6). - A **custom JSON control model with ELI/CELEX provenance** (standards evaluated and rejected: LegalRuleML, XBRL, OPA; OSCAL architecture copied, not adopted) (§7). - A **regulatory ingestion + change-detection design** over EUR-Lex/CELLAR (SPARQL + Formex XML + RSS) with article/paragraph-granular diffing and a mandatory human review gate (§8). - A **document pipeline** proven against both samples (tagged and untagged, numbered and unnumbered heading regimes, mojibake, footnote interleaving, pasted-template numbering collisions) (§9, §31). - A **three-layer evaluation engine** (deterministic → hybrid retrieval → LLM with schema-constrained output), an anti-hallucination verification gate, and a five-state decision contract (§13, §14). - An **incremental re-validation algorithm** with hash-based reuse that cuts LLM cost ~6–7× — platform LLM spend ≈ **\$500 / \$5k / \$50k per year at 1k / 10k / 100k firms** (§16, §27). - A **whitespace-confirmed market position** for ControlIQ: no surveyed vendor (≈20 profiled) offers uploaded-document validation against MiCA/DORA with clause-level evidence and a closed continuous-revalidation loop (§28).

Headline architecture decisions. Engine state lives in ControlIQ's PostgreSQL under its own schema — a single relational system of record (pgvector + FTS hybrid search; **no Neo4j, no OpenSearch at MVP**); Postgres transactional outbox at MVP → Temporal + SQS/SNS at enterprise scale; local-first extraction (Docling); self-hosted embeddings (BGE-M3); EU-pinned everything; RLS multi-tenancy with a DB-per-tenant enterprise path; append-only evaluations with full version pinning (regulation, control, prompt, model) so every finding is reproducible.

What the engine must never claim. Findings are *evidence gaps in a document*, not breach determinations, and never legal advice. DORA/MiCA are document-architecture-neutral — a policy missing from the WSP may legitimately live elsewhere. Severity grading and FINRA → EU analogies carry standing **REQUIRES LEGAL REVIEW** flags surfaced to the platform UI.

2. What "WSP" Means

Full analysis: regulatory/wsp-meaning.md.

2.1 Verified meaning (**VERIFIED FACT**)

- **WSP = Written Supervisory Procedures** under **FINRA Rule 3110(b)(1)**: every FINRA member "shall establish, maintain, and enforce written procedures to supervise the types of business in which it engages..." (<https://www.finra.org/rules-guidance/rulebooks/finra-rules/3110>, accessed 2026-08-17). FINRA Rule 3120 requires *annual testing* of WSP adequacy — US regulation already treats the WSP as a living document subject to continuous validation, which is precedent for this product's core concept.
- **"WSP" is not a defined term in MiCA or DORA.** EU law imposes *distributed* written policy/procedure obligations, never one monolithic manual (EUR-Lex: <https://eur-lex.europa.eu/eli/reg/2023/1114/oj/eng> and <https://eur-lex.europa.eu/eli/reg/2022/2554/oj>, accessed 2026-08-17). Nearest EU equivalents: MiCA **Art. 68** CASP governance arrangements (esp. Art. 68(4): "policies and procedures sufficiently effective to ensure compliance" — the master hook), the Title V Ch. 2–3 conduct policies (safekeeping, complaints, conflicts, outsourcing...), MiCA Art. 34 for ART issuers, and DORA **Arts. 5–6** (management-body responsibility; "well-documented ICT risk management framework... reviewed at least once a year") plus the written policies prescribed by RTS 2024/1774.

2.2 Product meaning (**ASSUMPTION**), per ControlIQ PRD §6)

In ControlIQ a WSP is a **firm's internal written compliance/supervisory-procedures manual, uploaded as one document** and decomposed into policy units mapped many-to-many onto the EU obligation hierarchy. Target uploaders are EU-scoped entities (primarily CASPs); the FINRA samples are structural test cases only.

2.3 Why NOT a MiCA white paper (sample evidence, VERIFIED)

MiCA *does* define a "crypto-asset white paper" (Arts. 6/8/9 — investor-facing token disclosure, ≥20-working-day NCA notification, no approval), so the name collision is real in loose usage. Ruled out here because both samples are demonstrably internal supervisory manuals: `Sample WSP.pdf` = WealthForge Securities, LLC, 154 pp, Jan 2024, FINRA/SIPC member, supervision chapters and appendices; `WSP Sample.pdf` = Triad Securities Corp. "Written Supervisory Procedures Manual", 199 pp, May 2013, deep numbered TOC of supervisory procedures. Zero EU instruments cited in either. The white-paper regime (MiCA Titles II–IV, Annexes I–III) is **explicitly excluded** from the control library — including it would be a category error.

2.4 Entity-type variance (drives the applicability engine, §11)

ENTITY	MICA POLICY LOCUS	DORA
CASP	Art. 68 + Title V Ch. 2–3 + service-specific Arts. 75–82	Yes — Art. 2(1)(f); full Chapter II (Art. 16 simplified framework does NOT cover CASPs)
ART issuer	Art. 34 + Title III + EBA internal-governance Guidelines	Yes
EMT issuer	Title IV via credit/e-money-institution status (EMD2/CRD overlay)	Yes, via that status
Plain offeror	White paper + Art. 14 conduct only	Generally out of scope

Proportionality: DORA Art. 4 (size/risk/complexity) and Art. 3(60) microenterprise carve-outs (<10 staff, ≤€2m) modeled as firm attributes.

2.5 Open questions and legal flags

OPEN: supported entity types at launch; NCA-specific documentation expectations beyond L1/L2; complete live RTS/ITS inventory re-verified against EUR-Lex; per-Member-State grandfathering tail cases. **REQUIRES LEGAL / COMPLIANCE INTERPRETATION:** section-to-article mapping of a monolithic manual; whether one manual can satisfy obligations expecting distinct board-approved policies; proportionality determinations; severity grading (platform output is advisory, not legal advice).

3. Sample WSP Findings Summary

Detail: `notes-sample-wsp-1.md`, `notes-sample-wsp-2.md`, `sample-wsp-comparison.md`, `sample-wsp-structure.md`.

	WSP1 — <code>SAMPLE WSP.PDF</code>	WSP2 — <code>WSP SAMPLE.PDF</code>
Firm / date	WealthForge Securities (Richmond, VA), Jan 3 2024; PDFium re-export 2026-06	Triad Securities Corp., May 1 2013; Word 2007 export
Format	154 pp, PDF 1.7, untagged , text-native	199 pp, PDF 1.5, tagged , text-native
Structure	11 flat chapters + 8 appendices (letters F, G, I, K missing); sub-headings unnumbered bold	Sections 1.0–20.0, depth-3 decimal numbering (797 numbered headings) + Appendices A–G; §18 AML is a pasted FINRA template with its own colliding 1.–20. numbering
Page anchoring	printed page = physical page (verified)	printed footer <code>- N -</code> = physical page (verified)
Seeded contradictions	AML-CO = Kolby Griffin (p.44, App. A) vs Jim Raper (App. D p.142) ; title drift (Arles FinOp vs CFO); Raper holds 5 roles	Employee-account review frequency stated 3 ways (2.4.3 vs 9.5.1/9.5.2); Ray Holland assigned "Branches" p.14 then never reappears; e-comms governed in both §2.11 and §5.7
Staleness	Cover 2024 vs AML appendix rev 2022-06-28 vs BCP approval 2023-01-05; FINRA 1250 cited though superseded by 1240; dead <code>finra.complinet.com</code> URLs	Whole document stale (latest amendment 2013); 67 NASD-era citations; superseded SEC Rule 11Ac1-6; 9 dead URLs
DORA-relevant content	BCP (App. B, no RTO/RPO, no test schedule); cybersecurity p.38 + App. L (breach reporting "without delay" but no classification/timelines); named ICT vendors SMARSH/ShareFile/AWS + parent-company framework	Near-total gap: BCP absent (one contact-update mention p.44), ICT/cyber near-absent — the negative test case
Extraction hazards	~69 footnotes interleaving mid-paragraph; superscript markers merging into words ("gratuity.44"); SymbolMT <code>Σ</code> mojibake	Smart-quote mojibake (<code>—</code> ×245, <code> </code> ×250, <code>'</code> ×359); dash variance (U–4/U-4); glued headings ("20.1.1In General"); TOC ↔ body drift
Prompt injection	none found (still treated as untrusted)	none found (still treated as untrusted)

Why the pair is a good corpus: they bound the design space from both ends — tagged vs untagged, deep numbering vs flat headings, TOC-with-pages vs TOC-without-pages, component staleness vs whole-document staleness, partial DORA evidence vs total DORA absence, and two disjoint extraction-hazard classes. The seeded contradictions and staleness chains form a labeled golden set (12 positive contradiction cases, 2 negative controls, 1 drift monitor — see [sample-wsp-consistency-analysis.md §3](#)).

4. Regulatory Landscape 2026

All dates **VERIFIED** (accessed 2026-08-17). Detail: [regulatory/wsp-mica-analysis.md §1–2](#), [regulatory/wsp-dora-analysis.md](#).

Binding vs guiding (authority tiers the control model must encode):

TIER	INSTRUMENTS	BINDINGNESS
L1	MiCA (EU) 2023/1114 (fully applicable 2024-12-30); DORA (EU) 2022/2554 (applies 2025-01-17)	Binding regulation, directly applicable
L2	Commission Delegated/Implementing Regulations (RTS/ITS) — MiCA: CDR 2025/305 + CIR 2025/306 (authorisation), CDR 2025/294 (complaints), CDR 2025/1142 (conflicts), CDR 2025/1140 (record-keeping), CDR 2025/416 (order-book records), CDR 2025/885 (market abuse + STOR, in force 2025-09-09). DORA: CDR 2024/1772 (incident classification), 2024/1773 (third-party policy), 2024/1774 (ICT risk framework), CIR 2024/2956 (Register of Information), CDR 2025/301 + CIR 2025/302 (incident reporting: 4h/24h initial, 72h intermediate, 1-month final), CDR 2025/532 (subcontracting), CDR 2025/1190 (TLPT, applicable 2025-07-08)	Binding once in OJ; each instrument number pending final EUR-Lex ELI re-verification (library caveat)
L3	ESMA/EBA Guidelines (comply-or-explain): suitability + periodic statement (ESMA35-1872330276-2031, Mar 2025); knowledge & competence (…-2380, Jul 2025); reverse solicitation (Q1 2025); CASP authorisation supervisory briefing (Jan 2025); EBA Travel Rule GLs; EBA ART internal-governance GLs. ESMA Level 2/3 table ESMA75-113276571-1510 (Jul 2025) is the index	Guidance — findings based solely on L3 must be labeled non-binding
Q&A	ESMA/EBA Q&As (e.g. ESMA Q&A 2364: transitional-regime VASPs are NOT DORA-scoped until CASP authorisation)	Non-binding interpretive aids — can <i>invalidate</i> prior control interpretations without any text change (see §16)
Adjacent	Travel Rule Reg. (EU) 2023/1113 (applies 2024-12-30) + EBA GLs; AMLR (EU) 2024/1624 (CASPs obliged entities from 2027-07-10)	Separate regime — modeled as <code>regime: AML-ADJACENT</code> , never conflated with MiCA findings

Key 2026 posture: grandfathering under MiCA Art. 143(3) ended by 2026-07-01 → the platform should still capture per-firm authorisation status as metadata (drives DORA scoping per ESMA Q&A 2364; **REQUIRES LEGAL REVIEW** per firm). EU AI Act status is covered in §25.

5. MiCA WSP Control Library

Full library (24 controls, JSON): [regulatory/wsp-mica-analysis.md §4](#).

- Scope:** Title V (Arts. 59–85) + Title VI (Arts. 86–92) only. White-paper regime excluded. Master hook = **Art. 68(4)** — the WSP *is* the "policies and procedures sufficiently effective to ensure compliance" artefact; MICA-WSP-008 (critical) validates the manual's own review cycle, version log, and approval evidence.
- Coverage:** authorisation/perimeter (001–003, incl. the **Art. 62(2) application-dossier checklist as a deterministic WSP table-of-contents test**), conduct (004–005), prudential (006 — Annex IV €50k/€125k/€150k classes), governance/personnel/records (007–012, incl. 5-yr retention), safekeeping & client funds (013–014 — **D+1 deposit rule deterministically checkable**), complaints/conflicts/outourcing/wind-down (015–018), service-specific custody/platform/exchange/execution/advice (019–022), market abuse + STOR (023, critical), AML-adjacent (024).
- Severity scheme:** critical = authorisation, prudential, safekeeping/custody, platform rules, market abuse; high = conduct, governance, complaints, conflicts, outsourcing, records, AML; medium = notifications, wind-down, marketing.
- Validation types:** most controls hybrid — a deterministic trigger (named policy present, stated retention ≥5y, RTS template fields) gating a semantic adequacy judgment.
- Caveat recorded in the library:** OJ instrument numbers were cross-verified via secondary trackers; production ingestion must re-resolve each CDR/CIR to its EUR-Lex ELI URL before controls activate.

6. DORA-WSP Applicability Verdict

Full analysis and 15-control JSON: [regulatory/wsp-dora-analysis.md](#).

Verdict (VERIFIED): a WSP manual is **not itself subject to DORA**. DORA regulates financial entities and demands specific *documented* policies/procedures; it never names a consolidated manual. Therefore **every DORA finding is an evidence-gap statement ("the WSP does not document policy X per Art. Y")**, **never a breach determination** — the policy may live in another document. This phrasing rule is enforced in the finding model (§17).

Classification applied per article:

- DIRECT WSP REQUIREMENT** (explicit documented-policy obligations a manual can legitimately contain): Art. 5(2) governance/roles; Art. 9(4) infosec/access/change/patch policies (+RTS 2024/1774); Art. 11(1) ICT BC policy; Art. 13(6) training; Art. 14 crisis communication + spokesperson; Arts. 17–19 incident management/classification/reporting procedures (reporting = **DORA-WSP-011, the only CRITICAL**); Arts. 24–25 testing programme description; Art. 28(2)/(4)–(8) third-party strategy, due diligence, exit-strategy procedures.
- INDIRECT REGULATORY RELATIONSHIP:** Art. 6 framework/strategy, Art. 11(3) plans/BIA, Art. 28(3) register-maintenance *procedure* — WSP references; primary evidence lives elsewhere.
- NOT APPLICABLE to WSP** (never raise "missing from WSP"): Register of Information data (ITS 2024/2956 — structured dataset), Art. 30 contract clauses, test execution reports, submitted incident reports, standalone strategies/BIA/recovery plans, Art. 31+ CTPP oversight, Art. 11(10) loss reporting.
- REQUIRES LEGAL INTERPRETATION:** firm scoping (authorisation status per ESMA Q&A 2364), microenterprise status (Art. 3(60) → `microenterprise_sensitive` flag suppresses/downgrades specific controls), TLPT designation (Arts. 26–27 excluded from default controls), and single-manual vs document-suite architectures.

MVP inclusion verdict: include DORA from day one. The controls are defensible as evidence-gap checks, the sample corpus proves the gap-profile output is the product's clearest value demonstration (WSP2 → 6+ severity-graded absence findings), and MiCA Art. 68(7) cross-references DORA anyway — a MiCA-only validator would be incomplete on its own terms.

7. Regulatory Control Model

Full evaluation: [regulatory/control-model.md](#).

Recommendation (ARCHITECTURAL): hybrid = custom JSON control model + ELI/CELEX provenance identifiers + Akoma-Ntoso-aware ingestion.

STANDARD	VERDICT	REASON
Akoma Ntoso / AKN4EU	Use for <i>structure addressing</i> only (AKN-style eIds <code>art_68_para_7</code>)	Models legal text, not controls; EUR-Lex does not serve AKN for retrieval — ingestion is Formex/XHTML-first
LegalRuleML	Reject; borrow concepts (obligation type, bearer) as JSON fields	No ecosystem; validation here is LLM-driven, not logic-programming
XBRL/iXBRL	Reject	Data-point reporting, not narrative-procedure validation
OSCAL (NIST)	Copy architecture (catalog/control/parts/back-matter), don't adopt serialization	Closest structural analogue but no ELI/effective-date semantics; JSON → OSCAL export mapping feasible later
OPA/Rego	Reject for compliance semantics (fine for platform authz)	Boolean rules over structured input ≠ semantic document judgment
ELI + CELEX	Adopt for all provenance	Official, versioned, point-in-time resolvable (e.g. CELEX <code>02023R1114-20240109</code> = <code>eur-lex.europa.eu/eli/reg/2023/1114/2024-01-09/eng</code>)
FIBO	Not adopted	Models instruments/entities, not obligations

Control object design rules: every control cites ≥1 CELEX + ELI anchor at article/paragraph granularity with a pinned `text_sha256` of the provision (cheap "did my provision change?" checks); L2/L3 attach as `related_provisions` / `guidance_refs` with explicit `authority_level` ; controls are **immutable per version** — any change flows through the human review gate; expected-evidence `sufficiency` is flagged **REQUIRES LEGAL REVIEW** by default. Illustrative JSON shape in control-model.md §3.

8. Regulatory Ingestion & Change Detection

Full design: [regulatory/regulatory-ingestion.md](#) · diagram: [regulatory-ingestion.mmd](#).

What the sources actually offer (**VERIFIED**): EUR-Lex/CELLAR provides a public SPARQL endpoint over the Common Data Model (amends/corrects/legal-basis relations), RESTful retrieval in XHTML/PDF/**Formex XML**, SOAP search (registered), predefined + custom RSS, CELLAR RSS/ATOM. ELI point-in-time expression URIs exist for consolidated texts. **Consolidation has no published SLA** — so amendment detection keys off **OJ metadata (daily, high reliability)**, with consolidated-text diffing once the expression appears (lag days—weeks; measure empirically). ESMA and EBA Interactive Single Rulebooks + Q&A tools are HTML-only, no API/export → content-hash monitoring, medium-low reliability, an accepted risk.

Pipeline: watchers (SPARQL polls on `32023R1114` / `32022R2554` relations + consolidated families `02023R1114-*` + OJ RSS + ESA page monitors) → fetch Formex/XHTML by CELEX/ELI → structural parse to article/paragraph/point tree with stable eIds + normalized SHA-256 per node → expression snapshot store → **tree diff** (modified/added/deleted/renumbered — renumbering detected by hash reverse-lookup) → ChangeSet (references ELI URI + eId, no bulk text) → **impact mapping** via the control → article inverted index (configurable blast radius: exact eId → parent article → citation-graph second ring) → **mandatory human review gate**: no control auto-activates; analyst approval creates immutable control versions tied to ChangeSet IDs and triggers incremental re-validation (§16). Effective dates from ELI/CDM metadata; transitional provisions flagged low-confidence → **REQUIRES LEGAL REVIEW**. Fetched regulatory content is itself untrusted LLM input.

9. WSP Processing Pipeline

Full evaluation: `wsp-analysis/sample-wsp-extraction-analysis.md` · diagram: `wsp-processing.mmd`.

```
upload → validate (MIME/magic, no-JS/no-encryption) → malware scan → sha256 → version → parse (text-native fast path; OCR fallback) → normalize (Unicode/mojibake/dash/de-glue) → section tree → tables/forms → claim & entity extraction → chunking → embed → index
```

Tooling decisions: - **Primary structure parser: Docling** (MIT, fully local — decisive for EU residency; DL layout + TableFormer; per-item page+bbox provenance) + **PyMuPDF for span-level font features** needed by the unnumbered-heading detector (AGPL — **REQUIRES LEGAL REVIEW**; MIT fallback = pdfplumber). Tika/python-magic at the upload gate. **Both samples are text-native — zero OCR**; OCR fallback (OCRmyPDF/Tesseract, local) triggers at <~100 chars/page; cloud OCR (Azure DI \$10/1k pp; Texttract \$15/1k — cross-region service-improvement storage must be org-opted-out, **REQUIRES LEGAL REVIEW**; Google \$10/1k) only as per-tenant opt-in escalation. - **Section detection is a hybrid detector with four signal classes**, per-document weighted: decimal-numbering grammar (WSP2: 797 headings), font-size/bold heuristics (WSP1: unnumbered sub-headings), TOC reconciliation (page-driven for WSP1-class, title-match for WSP2-class — **TOC is a claim, not ground truth**), PDF structure tags when present. Plus **scoped numbering contexts** so a pasted template (WSP2 §18) opens a child scope instead of corrupting the tree; **appendices as first-class components** with own `revision_date` / `approval_evidence` (WSP1 App. A/B prove this is required); page parity measured per document (`page_offset`), never assumed. - **Mandatory pre-parse normalization:** mojibake repair (`\d(?:=[A-Z])`), footnote-marker stripping, footer removal. Footnote bodies extracted to **sidacar records** before chunking (WSP1's worst hazard). - **Evidence anchoring contract:** findings cite (`doc_sha256`, `version`, `section_id`, `page`, `bbox`); the section tree (`section_id`, `number`, `title`, `page_start`, `page_end`, `parent_id`, `numbering_scope`, `component_metadata`) is the addressing scheme every downstream stage keys on.

10. WSP Knowledge Model

The canonical representation of an ingested WSP — every element below was *forced* by the samples:

- Document** → **versions** → **components** → **section tree** (`ltree` path, per-section `text_sha256`). Components = appendices/sub-documents with independent revision dates and approval evidence.
- Chunks** (section-aware, 300–800 tokens, never crossing section boundaries; `numbering_scope`; two-layer text: `text_normalized` for indexing, `text_raw` + offset maps for verbatim span verification; contextual-retrieval prefix; roster tables flagged `is_roster` and retrieved whole). See `sample-wsp-rag-analysis.md`.
- Typed claims** extracted per chunk (schema in `sample-wsp-consistency-analysis.md` §2): `role_assignment` | `obligation` | `frequency` | `threshold` | `date_assertion` | `citation` | `cross_reference` | `prohibition` | `delegation`, each with subject/predicate/object in **canonical + raw** form, qualifiers (ISO-8601 frequency with `vague` modifier, thresholds, effective dates), full provenance (chunk, section, page, char span, quoted span), and confidence.
- Normalization layers:** character → date ("2/6/03", "January 3rd, 2024" → ISO) → frequency ("annually"/"periodically" → P1Y / `vague:true`) → **role canonicalization** (controlled vocabulary seeded from the samples: `chief_compliance_officer` ← CCO/Director of Compliance; `financial_operations_principal` ← FinOp/FINOP/CFO-drift; `aml_compliance_officer` ← AML CO/AML Compliance Person) → conservative person-entity resolution ("Jim Raper" = "James L Raper Jr.") → citation normalization with a **supersession registry** (FINRA 1250 → 1240, NASD → FINRA, SEC 11Ac1-6 → 606; EU analog fed by the ingestion pipeline).
- Cross-reference graph:** resolved internal links ("See Section 2.11", "full program in Appendix A") with dangling-link detection; external evidence pointers ("contact Operations", "SEE FILE") classified as evidence-externalization findings.
- Synthetic chunks:** one section-inventory (TOC-derived outline) chunk per version — required for absence proofs (§14).

Supervisor designations, review frequencies, and rule citations — the three entity families the samples forced — are thus first-class, queryable claim types, not free text.

11. Applicability Engine & False-Positive Prevention

- **Applicability filter runs before any retrieval or LLM call.** `requirements.applicability_expr` (JSONB) evaluated against firm metadata: entity class (CASP/ART/EMT), authorised service list (custody/platform/exchange/execution/advice/RTO/transfer), authorisation status (drives DORA scoping per ESMA Q&A 2364), microenterprise status (suppresses/downgrades `microenterprise_sensitive` DORA controls), holds-client-assets flags. Out-of-scope controls terminate as `NOT_APPLICABLE` with a recorded reason — typically ~25% of the library per firm.
- **False-positive prevention layers** (each grounded in a sample case): 1. *Coherent-fallback discrimination*: "prohibits currency transactions" + CTR procedure must NOT flag (WSP1 N-01) — calibration case for the NLI tier. 2. *Conditional checks*: reviewer-cycle rule fires only if roster resolves CEO = CCO (WSP1 N-02). 3. *Scope disambiguation before frequency-conflict findings*: daily order-ticket review vs monthly account review may be different obligations on one topic (WSP2 C-06). 4. *DORA phrasing rule*: absence findings are evidence gaps, never breaches (§6). 5. *ANALOG ≠ compliant, but also ≠ absent*: US-regime analogs (records, suitability, AML) are reported as PARTIAL/ANALOG with named EU-specific sub-gaps and a `REQUIRES_LEGAL_REVIEW` flag — never as clean PASS or clean FAIL ([sample-wsp-control-mapping.md](#)). 6. *Verification gate + asymmetric human review* (§13–14) before anything is alerted.

12. WSP & Control Versioning

- **WSP versions are immutable**: new upload (new sha256) ⇒ new `wsp_version` with `supersedes_id`; section-level diff by `(path, text_sha256)` with text-hash fallback across paths to absorb renumbering-only edits.
- **Control versions are immutable**: regulation change or human edit creates a new `control_version` (logic JSONB, `prompt_sha256`, `model_id`, `effective_from`, `change_reason` = ChangeSet ID, approver) through the review gate.
- **Evaluations are append-only** and pin *every* version axis: regulation expression, requirement, control version, prompt hash, model id, embedding model, retriever config, input hash. Reconstructable at any date: "what did the platform believe on X, evaluated with which control logic, against which regulation text."
- The samples motivate two distinct staleness classes the versioning model distinguishes: **stale components inside a current document** (WSP1: 2022 AML appendix under a 2024 cover) vs **a stale document** (WSP2: nothing after 2013) — hence component-level revision metadata.

13. Three-Layer Compliance Evaluation Engine

Diagram: [compliance-evaluation.mmd](#).

- **Layer 1 — Deterministic (no LLM, cached by `(control_version, section_text_sha256)`)**: TOC ↔ body reconciliation; appendix-letter/numbering continuity; required-section presence (e.g. the Art. 62(2) dossier checklist); roster integrity; date coherence and claimed-cycle-vs-evidence checks; citation extraction + supersession/staleness registry; dead-URL checks; numeric threshold extraction (retention ≥5y, D+1, capital classes, RTS template fields); frequency-triple inventories; cross-reference/dangling-link resolution; signature/approval presence; blank-placeholder detection.
- **Layer 2 — Hybrid retrieval**: per-control query templates + FINRA ↔ EU synonym expansion → dense (BGE-M3, pgvector HNSW) + lexical (BM25/tsvector) filtered to one `wsp_version`, RRF-fused, cross-encoder reranked to top 10–20, parent-section expanded, 1-hop cross-ref expansion, whole-roster co-retrieval.
- **Layer 3 — LLM judgment**: schema-constrained JSON (decision, confidence, chunk_id citations, verbatim `quoted_span`, named gaps); model tiering (Haiku-class screen, Sonnet-class escalate; per-control `model_id` pinning); followed by the deterministic **evidence-verification gate** (§14).

Decision contract (per control × WSP version):

DECISION	MEANING
PASS	Cited WSP evidence satisfies the control's expected evidence
PARTIAL	Evidence exists but incomplete/outdated/contradicted — named sub-gaps required
FAIL	No adequate evidence, including verified absence (absence must cite the searched scope + nearest rejected candidate)
NOT_APPLICABLE	Out of scope for the firm's profile — reason recorded
NEEDS_HUMAN_REVIEW	First-class terminal state: low confidence, contradiction, span mismatch, or interpretive question

Every non-N/A decision carries ≥1 citation whose page/section fields are **filled by the system from chunk metadata — the LLM only selects chunk_ids and never invents page numbers.**

14. RAG/LLM Architecture & Injection Defenses

Detail: [ai/rag-architecture.md](#), [wsp-analysis/sample-wsp-rag-analysis.md](#), [security/llm-security-governance.md](#) · diagram: [rag-llm-flow.mmd](#).

- **Embeddings:** self-hosted **BGE-M3** (open weights, multilingual, dense+sparse, 8k ctx) for EU residency; jina-v3 rejected (CC-BY-NC). Contextual-retrieval prefixes before embedding/BM25 (~49% retrieval-failure reduction, ~67% with reranking — Anthropic benchmark). Reranker: BGE-reranker-v2-m3.
- **Anti-hallucination gate (deterministic, pre-persistence):** (1) span existence — `quoted_span` must verbatim-match the stored chunk at recorded offsets; fail → regenerate once → NEEDS_HUMAN_REVIEW; (2) citation integrity vs chunk metadata; (3) LLM-as-judge claim-level groundedness (<0.8 flag, <0.7 block); (4) table claims re-checked against the raw cell grid.
- **Confidence & human review:** composite score (retrieval strength, groundedness, k=3 self-consistency, calibration); <0.6 always human; 0.6–0.8 auto-PASS allowed but FAIL/PARTIAL need confirmation (**asymmetric: FAIL-recall is the metric that matters — a missed gap is the worst error**); >0.8 auto with sampled QA; trust ramp for new tenants. Proposed gates: FAIL-recall ≥0.9, PASS-precision ≥0.95.
- **Prompt-injection defenses (OWASP LLM01:2025 anchor):** instruction/data separation with delimited data blocks; **no-tool core loop** (retrieval injected by orchestrator); narrow output contract makes injection unprofitable (a forced PASS still needs verifiable entailed spans); ingestion-time injection scan + **render-vs-extraction hidden-text diff** (PhantomLint-style) + rule layer (white-on-white, <4pt, off-page, Tr 3); never fetch URLs found in documents (static EU-regulator allowlist only); no markdown-image rendering of model output (exfil beacons); tenant filtering at the DB layer, never in prompts; red-team poisoned-WSP corpus in CI. Real-world document-poisoning prevalence ~1% and >90% non-imperative phrasing — scanning alone is insufficient, hence defense in depth.

15. Cross-Section Consistency Engine

Detail: [wsp-analysis/sample-wsp-consistency-analysis.md](#).

Contradiction detection = **extract typed claims** → **normalize** → **compare**, in three tiers:

1. **Deterministic joins:** group claims by canonical role → conflicting persons (catches the WSP1 AML-CO conflict); by person → title sets and role-count aggregates; by (topic, obligation) → frequency/owner sets; date-ordering rules (cover ≥ component dates; claimed cycle vs latest evidenced review); registry lookups (superseded citations); roster-vs-body mention joins; repeated-claim clustering for **version-drift monitoring** (e.g. the thrice-repeated "10% of subscribers" claim — alert when one instance changes in a future version).
2. **Semantic (NLI/LLM):** scope disambiguation of tier-1 candidate pairs; NLI over section pairs flagged by the cross-ref/duplication graph (summary-vs-appendix drift); prohibition-vs-procedure coherence calibrated on the must-not-flag cases.
3. **Conditional rules** parameterized by other extractions (reviewer-cycle case).

Severity guidance (`ASSUMPTION`, calibrate with compliance experts): high = conflicting designation of a mandated function (MiCA Art. 68 / DORA Art. 5 analogs), claimed-cycle-without-evidence; medium = frequency conflicts, duplicated-policy divergence, orphan designations, stale citations; low = title drift, TOC drift, style. Concentration/segregation-of-duties findings are proportionality-dependent → `REQUIRES LEGAL / COMPLIANCE INTERPRETATION`. Contradiction findings always enter `NEEDS_HUMAN_REVIEW` first and carry **two** evidence anchors minimum.

16. Incremental Revalidation Algorithm

Full pseudocode: [architecture/incremental-revalidation.md](#) · diagram: [regulatory-revalidation.mmd](#).

Core artifact: `control_section_dependency` — written *at evaluation time*, one row per section actually consulted, recording `section_text_sha256`, `reg_text_sha256`, `prompt_sha256`, `model_id`. An evaluation is **stale iff any recorded input hash mismatches current state**; everything else reuses the prior verdict at zero LLM cost (`reused_from_evaluation_id`).

```
python def revalidate_for_change(change_id): impacted_cvs = SQL: paragraphs -> control_requirement_map -> control_versions # regulation-side impact | curated change_impacts (impact != 'none') targets = SQL: control_section_dependency X latest_evaluation # firm-side blast radius fanout(targets, impacted_cvs) # Temporal batches of ~500 firms
```

```
def plan_control(cv, wsp_version): if not applicable(cv, firm): return NOT_APPLICABLE # short-circuit if cv.kind == 'deterministic': return run_locally() # never LLM ev = retrieve_evidence(cv, wsp_version) # embedding cache (model, text_sha256) key = H(prompt_sha256, model_id, chunk_hashes, reg_text_sha256) if prior(key) and trigger_allows_reuse(cv): return reuse(prior) # exact-match verdict reuse return LLMTASK(key) # true residue only # trigger_allows_reuse == False when change_impacts.impact == 'invalidates': # interpretation changed though text didn't (e.g. an ESMA Q&A) — hashes cannot see this; # it is driven by the curated table. REQUIRES_LEGAL_REVIEW at curation time, by design.
```

```
def execute(tasks): # grouped by (model, prompt) => provider prompt-cache hot; Batch API (-50%) def finalize(run): # diff vs previous run per control: # NEW_GAP / WORSENER -> real-time alert with dedupe_key(firm, control, verdict, severity) # IMPROVED / RESOLVED -> digest; UNCHANGED -> silent
```

Reuse layers, cheapest first: deterministic → applicability filter → input-hash verdict reuse → embedding cache → retrieval-set reuse → provider prompt cache (~0.1× reads on the shared prefix) → Batch API. Idempotency via `input_sha256`; partial runs visible and re-drivable through `evaluation_runs.status`.

17. Finding Model & Evidence Graph

Diagram: `finding-lifecycle.mmd`.

- **Finding** = durable, deduplicated projection over append-only evaluations: `kind` (`gap` / `partial` / `contradiction` / `staleness` / `consistency` / `injection-artifact`), `severity`, `status` (`open` → `acknowledged` → `in_remediation` → `resolved` | `waived`; `needs_human_review` → `open` | `dismissed`), `first_seen_run_id` / `last_seen_run_id`, stable dedupe key.
- **Evidence graph**: every finding links (a) ≥1 WSP anchor (`doc_sha256`, `version`, `section_id`, `page`, `bbox`, `quoted_span`) — two anchors for contradictions; (b) the regulation side via control version → requirement → paragraph eId → ELI expression URI; (c) the eval record with all pinned versions (§25). Absence findings link the searched scope + section-inventory chunk + nearest rejected candidate. DORA findings carry the evidence-gap phrasing; ANALOG findings carry `REQUIRES LEGAL REVIEW`.
- **Remediation**: `remediation_items` (assignee, due date, plan, status) with an append-only `remediation_events` trail; resolution requires a re-evaluation verdict change, not a manual status flip; waivers are documented, audited risk acceptances.
- Human overrides never mutate — they append with `supersedes_eval_id` and feed the golden set.

18. Compliance Scoring Methodology

(Synthesized; `ARCHITECTURAL RECOMMENDATION`, thresholds `ASSUMPTION` — calibrate with compliance advisors.)

- **No single "compliance score" sold as assurance**. The platform reports a **posture profile**, never a certificate: per-regime (MiCA / DORA / AML-adjacent shown separately), per-domain (governance, safekeeping, complaints, ICT risk, incident, third-party...), and per-severity rollups.
- **Per-control state** = $\text{decision} \times \text{severity} \times \text{confidence} \times \text{freshness}$ (evaluated against current regulation expression?). **Domain score** = weighted coverage: $\frac{\sum \text{weight}(\text{severity}) \times \text{state}}{\sum \text{weight}(\text{applicable})}$, with PARTIAL counted fractionally and NEEDS_HUMAN_REVIEW excluded from the denominator but displayed as "unresolved".
- **Two orthogonal axes reported separately**: *coverage* (is each expected policy present at all — deterministic-heavy) and *adequacy* (does present text satisfy the control — semantic). Conflating them hides exactly the ANALOG trap the sample mapping exposed.
- **Trend, not snapshot**: score deltas are computed per run pair (the NEW_GAP/WORSENER/IMPROVED machinery of §16), so the headline metric is directional ("posture worsened on DORA incident reporting after CDR 2025/301 activation").
- Guardrails: scores suppressed until human-review backlog for critical controls is cleared; ANALOG/adjacent-regime findings capped from ever producing PASS-level contribution; scoring formula versioned like a control (score changes must be attributable to formula vs content).
- **REQUIRES LEGAL REVIEW**: any customer-facing wording implying regulatory assurance.

19. Alerting Rules & Dedup

- **Real-time alerts fire only on** `NEW_GAP` and `WORSENER` (severity-rank increase). IMPROVED/RESOLVED go to a daily/weekly digest; UNCHANGED is silent.
- **Dedupe key** `firm:control:verdict:severity` (unique on `notifications.dedupe_key`) prevents re-alerting the same state across successive runs; a resolved-then-reopened finding re-alerts (state changed).
- **Regulatory-change notices** are separate from finding alerts: when a ChangeSet passes the human gate, affected firms get one consolidated "regulation changed → N of your controls re-validated → M findings changed" notice per change, not per control.
- Severity-based routing: critical → immediate (email/webhook); high → daily; medium/low → digest. Per-tenant channel config; alert fatigue is a first-class product risk given 39+ controls × continuous change.
- Prompt-injection artifacts and quarantined documents alert the *platform* ops channel, and the tenant only with reviewed wording.

20. Dashboard Spec

(`ARCHITECTURAL RECOMMENDATION` — minimum viable analyst surface.)

1. **Posture overview**: per-regime domain heatmap (coverage vs adequacy axes), open findings by severity, trend sparkline per domain, unresolved-review counter.

- 2. **Findings queue:** filter by regime/severity/status/control; each finding shows decision, rationale, **verbatim cited spans with page/section deep-links into the rendered PDF**, confidence components, injection-scan flags, and the regulation side (article text via ELI link) — the reviewer sees both ends of the evidence graph. Accept / override (reason-coded) / assign remediation actions.
- 3. **Document view:** section tree with per-section finding badges; component metadata (appendix revision dates, approval evidence); version diff view (changed sections highlighted, findings delta).
- 4. **Regulatory change feed:** ChangeSets affecting this firm, with instrument, eId-level diff summary, affected controls, revalidation status ("how far along is the DORA RTS revalidation" — served by workflow visibility).
- 5. **Remediation tracker:** items by assignee/due date; resolution requires re-evaluation pass.
- 6. **Admin/audit:** eval-record explorer (version pins), export (watermarked, audited), firm profile editor (entity class, services, authorisation status, microenterprise flag — the applicability inputs).
- 7. Every AI-generated finding **labeled as AI-generated** (EU AI Act Art. 50 posture, §25).

21. Database Design Summary & Neo4j Verdict

Full schema: [architecture/data-and-events.md](#) · ER diagram: [database-er.mmd](#).

- **Single PostgreSQL ≥16 system of record** for all entities: firms → wsp_documents → wsp_versions → wsp_sections (ltree, per-section `text_sha256`) → chunks/claims/evidence; global regulations → regulation_versions → articles → paragraphs → requirements; controls + control_versions + control_requirement_map + expected_evidence; append-only evaluation_runs/evaluations (REVOKE UPDATE/DELETE + trigger, monthly partitions), findings/remediation projections, regulatory_changes/change_impacts, notifications, audit_log. Regulatory content is global/shared; tenant data references it read-only.
- **Hybrid search in-DB:** pgvector HNSW + Postgres FTS, RRF-fused in SQL. Queries are always filtered to one wsp_version (~400 chunks) so even 100k firms (~120M vectors, hash-partitioned by firm) is trivial per query. **OpenSearch deferred** — justified only by cross-tenant faceted search or 100M+ unfiltered high-QPS vectors; every extra datastore is also an extra EU-residency surface and sub-processor.
- **Neo4j: rejected.** The "dependency graph" is ≤5 fixed typed hops = indexed joins; the section tree is bounded and handled by ltree/recursive CTEs; the actual dependency index is the materialized `control_section_dependency` table written at evaluation time. Neo4j would add dual-write consistency, ops burden, and residency surface for zero query benefit. Future trigger (cross-regulation semantic inference at analyst scale) would be served by a read-only projection or Apache AGE, not a primary graph DB.

22. Event Architecture (MVP vs Enterprise)

Diagram: [event-driven.mmd](#) · detail: [data-and-events.md](#) §2.

- **MVP (≤1k firms):** Postgres **transactional outbox + job queue** (`FOR UPDATE SKIP LOCKED` , idempotency keys) — zero extra infrastructure, events durable in the system of record; pipeline steps as explicit job types with a `pipeline_runs` state row, deliberately shaped like Temporal workflows so migration is mechanical.
- **Enterprise (10k–100k): Temporal** (self-hosted EU or Temporal Cloud EU — verify residency contractually) for pipelines and the revalidation fan-out (`RegulatoryChangeWorkflow` → `RevalidateBatch` children, continue-as-new, Batch-API polling, cost-brake signals — the strongest single argument for durable execution: 5 controls × 60k firms = 300k evaluations against rate-limited APIs over days, resumable, pausable, visible); **SQS/SNS** for notifications/integration events; **Kafka only if** a replayable event log becomes a product feature.

23. Technology Stack

MVP stack:

LAYER	CHOICE	NOTE
System of record + search	PostgreSQL ≥16 + pgvector + FTS (RRF in SQL)	ltree, partitioning, RLS, append-only enforcement
Object storage	S3-class, EU region, per-tenant prefixes	originals immutable, sha256-pinned
Extraction	Docling (MIT) + PyMuPDF (AGPL — license buy or pdfplumber fallback) + Tika/python-magic gate + ClamAV	local-first; OCRmyPDF/Tesseract fallback
Embeddings / rerank	BGE-M3 + BGE-reranker-v2-m3, self-hosted EU	pinned versions; embedding cache by (model, text_sha256)

LAYER	CHOICE	NOTE
LLM	EU-endpoint managed API, zero-retention DPA; Haiku-class screen + Sonnet-class escalate; Batch API + prompt caching	per-tenant vendor configurability; Schrems II REQUIRES LEGAL REVIEW
Events	Postgres outbox + SKIP LOCKED workers	no broker
Regulatory ingestion	CELLAR SPARQL + Formex parser + RSS + ESA HTML hash-monitors	single egress component, domain allowlist
App	Python backend (ASSUMPTION), OIDC SSO + MFA, RBAC/ABAC	

Enterprise additions: Temporal (EU) · SQS/SNS · DB-per-tenant exception path + BYOK · self-hosted extraction at ~10k firms (managed-OCR cost crossover) · optional OpenSearch only on proven trigger · optional EU-sovereign / self-hosted generation models for vendor-refusing tenants.

24. Security Summary

Full architecture + threat model (T1–T13): [security/security-architecture.md](#).

Posture driver (**VERIFIED**): customers are DORA-regulated, so **the platform is an ICT third-party service provider under DORA Art. 28 ff.** — security is a sales artifact. Highlights: TLS 1.3 + mTLS everywhere; layered encryption at rest with **per-tenant DEK envelope encryption** (crypto-shredding on offboarding, BYOK path); FORCE RLS with DB-set tenant predicate + CI cross-tenant probe suite as release blocker; two append-only audit layers (domain eval records + hash-chained WORM security audit), content-free logs; **EU-pinned everything** with a short published sub-processor list; egress-less **parsing sandbox** (microVM/container, no network, cgroup limits) for hostile PDFs; single-egress SSRF-proofed fetcher (static allowlist, resolving proxy, never fetch document-derived URLs); data-leakage deny-list (no WSP text in logs/traces; embeddings never leave the boundary); supply-chain pinning + parser-CVE P1 watch; secrets via workload identity, no long-lived credentials.

25. AI Governance

Full detail: [security/llm-security-governance.md](#) §2–3.

- Eval records** (append-only) pin regulation snapshot, requirement, control version, prompt, model, embedding model, retriever config, decision, confidence components, verification results, human-review block — every finding reproducible, every drift attributable.
- Golden set:** human-labeled decisions + citations against both samples (mostly FAIL/N-A — deliberately tests negative-evidence handling) + **synthetic EU-flavored WSPs** for the PASS/PARTIAL classes; versioned with controls; overrides feed back as labels.
- CI regression** on every prompt/model/retriever/control change; headline metrics FAIL-recall (≥0.9), PASS-precision (≥0.95), NEEDS_HUMAN_REVIEW rate; drift monitoring on confidence/decision-mix/override-rate (override rate is the strongest live quality signal).
- EU AI Act (state 2026-08-17, **VERIFIED** with caveat):** in force since 1 Aug 2024; GPAI since 2 Aug 2025; **2 Aug 2026 was the Annex III high-risk milestone, but a provisional May-2026 Digital Omnibus deal would postpone Annex III obligations to 2 Dec 2027 (Annex I to Aug 2028) — not yet in the OJ; re-verify before relying.** Platform classification: most plausibly **not** Annex III high-risk (professional decision-support) — **REQUIRES LEGAL REVIEW**; Art. 50 transparency (label findings AI-generated) likely applies and is cheap. **Posture: build high-risk-adjacent hygiene anyway** (Art. 12 logging = eval records; Art. 14 oversight = human-review gates; Art. 15 accuracy = golden-set metrics) — DORA-regulated customers will demand equivalents contractually regardless.

26. Multi-Tenancy & Scale

- Default:** shared Postgres, **FORCE ROW LEVEL SECURITY**, firm_id on every tenant table, session GUC from the authenticated principal (PgBouncer-compatible via **SET LOCAL**). Scales to 100k firms with hash-partitioning of **wsp_chunks / evaluations**. **Schema-per-tenant rejected** (catalog bloat beyond ~100s). **DB-per-tenant** reserved as the enterprise exception path (same schema/code, connection routing by tier).
- Isolation beyond the DB: per-tenant object prefixes + IAM conditions, ID-only queue payloads, per-tenant rate limits and **LLM spend budgets**, single-tenant ephemeral parse sandboxes.
- Scale envelope (from cost model): 100k firms ≈ 120M vectors, 8M append-only eval rows/yr, 6TB objects — all comfortably inside the single-Postgres + partitioning design; per-query retrieval is always ~400 vectors (one wsp_version).

27. Cost Model Summary

Full model with cited 2026 prices: [architecture/cost-model.md](#).

- Verified unit prices (2026-08-17): Haiku 4.5 \$1/\$5 per M tokens; Sonnet 5 \$3/\$15; Batch ~50%; cache reads ~0.1x; text-embedding-3-small \$0.02/M (\$0.01 batch).
- Optimized mixed-tier cost ≈ **\$1.4/firm/yr** (LLM ≈ \$0.45; extraction \$0.90 if managed). Platform LLM spend ≈ **\$500 / \$5k / \$50k at 1k / 10k / 100k firms**; un-optimized all-Sonnet worst case ≈ \$900k/yr at 100k firms — the batch+cache+tiering+reuse stack is worth ~6–7x.
- Drivers ranked: semantic-call count → prompt structure for provider caching (shared prefix ~45% of input at 0.1x) → Batch API → model tiering → **extraction choice (managed OCR rivals LLM spend at 100k firms; switch to self-hosted Docling-class around 10k firms)** → embedding dedupe → storage lifecycle.
- Infra dominates at small scale (~\$1–2k/mo at 1k firms); model-API spend is not the dominant cost until ~100k firms.

28. Competitor Landscape & Differentiation

Full analysis (~20 vendors, capability matrix): [market/competitor-analysis.md](#).

- **Whitespace confirmed:** no vendor offers automated validation of an uploaded WSP-style procedures manual against MiCA/DORA with clause-level evidence + continuous revalidation — not in the US WSP home market (COMPLY, Oyster, Red Oak, ACA = consultants/templates/workflow) and not in the EU.
- Closest: **4CRisk.ai Compliance Map** (verified policy-vs-regulation gap analysis + remediation language; no MiCA/DORA content, no closed loop); **Corlytics + Clausematch** (obligation-to-policy-statement traceability, but author-in-platform, not uploaded-document); **Norm Ai** (\$120M Series C reported; decision-tree encoding + citation-per-finding; MiCA/DORA not named). Regulatory-intelligence incumbents (CUBE, Regology, Ascent, Vixio, Archer/Compliance.ai) stop at feeds/obligation registers. DORA vendors cluster on the Register of Information and incident workflow. "MiCA compliance" tooling in practice = AML/Travel Rule/on-chain analytics (\$100–500k/yr stacks).
- **Differentiation ranking (ASSUMPTION)**: (1) the closed continuous-revalidation loop; (2) evidence-cited, severity-scored findings on *uploaded* documents; (3) the EU-native curated MiCA/DORA control library (defensible content, not just software — the moat is content curation, not the LLM); (4) cross-regime + internal contradiction detection; (5) transparent mid-market pricing + free "top-10 gaps" upload wedge (public pricing absent across all direct competitors). ESMA's iXBRL white-paper PoC is a machine-readable-regulation tailwind.
- Honest threats: Corlytics/Clausematch, 4CRisk, Norm Ai could each reach parity — time-to-parity is a content-curation problem; ship the library and the loop first.

29. MVP Definition & Phasing

MVP is strictly WSP-only. One document type (a single uploaded PDF manual per firm), MiCA **and** DORA control libraries active from day one (per the §6 verdict), EU CASP firm profiles.

MVP scope: upload → local-first pipeline → section tree/claims/chunks → 39-control seed library → three-layer engine + verification gate + decision contract → findings with page/section evidence → consistency engine tier 1–2 → posture dashboard + findings queue + human review → append-only eval records → regulatory watchers with human-gated ChangeSets → incremental revalidation with alert-on-worsening → RLS multi-tenancy, EU pinning, parsing sandbox, outbox events.

Explicitly out of MVP: OpenSearch, Temporal (outbox suffices), Neo4j (never), DB-per-tenant, BYOK, cloud OCR default, DOCX ingestion, non-English WSPs, NCA-specific dossier packs, cross-document policy-suite support.

- **Phase 2 (post-MVP):** Temporal + SQS/SNS; control-library expansion (RTS-field-level deterministic checks, per-service depth); synthetic-EU golden-set maturation; remediation-language suggestions; webhook/GRC integrations; DB-per-tenant + BYOK; DOCX.
- **Phase 3:** multi-document policy suites for one firm (changes retrieval scope + cross-document person resolution); NCA-specific expectations; multilingual; analytics/benchmarking (anonymized, opt-in).
- **Future document types (quarantined subsection — NOT committed):** the architecture generalizes (controls + expected evidence + section-treed documents), so candidates exist — MiCA white papers vs Annex I/II/III field checklists, DORA Register-of-Information consistency vs the WSP, ICT contracts vs Art. 30 clause checklists, wind-down plans, BCPs as standalone uploads. Each is a *new* control surface with its own legal analysis; none dilutes the MVP. Any expansion re-opens the §2 terminology analysis for that document class.

30. Implementation Roadmap (Phases 1–9)

Effort in engineer-months (EM), ASSUMPTION-level estimates; phases overlap where dependencies allow.

#	PHASE	COMPONENTS	DEPENDS ON	EFFORT	KEY RISKS	DELIVERABLES
1	Foundations	Postgres schema (data-and-events.md), RLS, append-only enforcement, object storage, outbox workers, CI/CD, EU environments	—	6–8 EM	RLS/pooling misconfig (CI probe suite from day one)	Running skeleton, ER as migrations, audit layers
2	Document pipeline	Upload gate, sandboxed parsing, Docling+font-span extraction, normalization, hybrid section detector, component model, claims extraction, chunking+embedding	1	8–10 EM	Section-detector generality beyond 2 samples; PyMuPDF license	Both samples parse to correct section trees; golden extraction fixtures
3	Control library v1	39 seed controls encoded in the JSON model, EUR-Lex ELI re-verification of every instrument, expected-evidence specs, applicability expressions, legal review pass	— (parallel)	4–6 EM + legal	Instrument re-verification surprises; sufficiency criteria REQUIRE LEGAL REVIEW	Versioned control catalog with provenance
4	Evaluation engine	Deterministic layer, hybrid retrieval (pgvector+FTS+RRF+rerank), LLM layer with schema output, verification gate, decision contract, confidence + review thresholds	2, 3	8–10 EM	FAIL-recall on absence proofs; ANALOG discrimination	15-row proof-of-fit mapping reproduced automatically (§31)
5	Consistency engine	Claim comparison tiers 1–3, canonical vocabularies, supersession registries, drift monitors	2, 4	4–6 EM	Over-flagging (calibrate on N-01/N-02)	12 seeded contradictions detected, 2 negatives not flagged
6	Findings, scoring, UI	Finding/evidence graph, remediation, posture dashboard, review queue with span deep-links, alerts + dedup	4, 5	6–8 EM	Alert fatigue; score-wording legal review	Analyst-usable product; pilot-ready
7	Regulatory ingestion	CELLAR/SPARQL watchers, Formex parser, tree diff, ChangeSets, impact mapping, human review gate UI, ESA HTML monitors	3	6–8 EM	Consolidation lag; ESA HTML fragility	Live change feed driving gated control versions
8	Incremental revalidation	Dependency index, reuse layers, fan-out (outbox → Temporal), Batch API integration, alert-on-worsening, cost brakes	4, 7	4–6 EM	Silent stale-reuse bugs (hash discipline); provider limits	Change-to-alert loop closed end-to-end
9	Hardening & go-live	Red-team injection corpus, hidden-text diff, golden-set gates in CI, drift dashboards, pen test, DORA-vendor due-diligence pack, AI Act posture memo, pilot onboarding	all	4–6 EM	EU AI Act status flux; Schrems II vendor terms	GA-ready platform + compliance artifacts

Critical path: 1 → 2 → 4 → 6; 3 and 7 run in parallel from the start (the control library and legal review are the schedule's long pole, not engineering).

31. Architecture Proof-of-Fit Against the Two Samples

The twelve proof-of-fit questions (brief §39), answered with sample evidence — the full 15-row control-mapping table is in [wsp-analysis/sample-wsp-control-mapping.md](#):

#	QUESTION	VERDICT	SAMPLE EVIDENCE
1	Can we build a correct section tree for both structural regimes?	Yes — hybrid 4-signal detector	WSP2's 797 numbered headings + tag tree; WSP1's TOC-page-numbers + font-span heuristics; §18 scope-switch handled by numbering contexts
2	Can findings cite page/section evidence reliably?	Yes	Printed=physical page parity verified in both; treated as measured <code>page_offset</code> , not assumption
3	Can we detect internal contradictions?	Yes — claim extraction + 3-tier comparison	AML-CO Griffin-vs-Raper (deterministic once claims typed); frequency 3-ways (hybrid); orphan designation Holland (hybrid)
4	Can we avoid false contradictions?	Yes — calibration cases exist	Currency-prohibition + CTR fallback; CEO/CCO reviewer cycle (conditional rule)
5	Can we detect staleness?	Yes — deterministic	Component chain (2024 cover vs 2022/2023 appendices) and whole-document (2013 + NASD rulebook); superseded-rule registry (1250 → 1240, 11Ac1-6 → 606); dead URLs

#	QUESTION	VERDICT	SAMPLE EVIDENCE
6	Can we prove absence (the MISSING column)?	Yes — negative-evidence protocol	WSP2 yields a near-total DORA gap profile (6+ absence findings); section-inventory chunk + nearest-rejected-candidate citation
7	Can we grade partial evidence with named sub-gaps?	Yes	WSP1 BCP present but no RTO/RPO/test schedule — deterministic token absence under semantic judgment
8	Can we resist the ANALOG keyword trap?	Yes — element-level judgment	"records"/"suitability"/"AML" all present in US form; engine judges against EU-specific elements (5-yr wording, 12-month statement, travel-rule fields) and flags REQUIRES LEGAL REVIEW
9	Does applicability gating work?	Yes	Advice/PPAET controls scope by service list; DORA microenterprise flag; per-firm authorisation status
10	Can extraction survive real-world hazards?	Yes — normalization + sidecars	Footnote interleaving, merged superscripts, mojibake, dash variance, glued headings, template numbering collision — all inventoried with mitigations
11	Do incremental hooks hold on these documents?	Yes	Chunk identity (section_id, text_sha256) ; a roster-only fix re-embeds one section; dependency index re-touches only chunks previously retrieved per control
12	Is the untrusted-data posture testable?	Yes	Both samples scanned clean (baseline fixtures); red-team corpus + render-diff specified

Architecture gaps identified from the sample WSPs (honest list): 1. Two same-genre US documents cannot validate EU-specific conflict classes or the PASS class at all — **synthetic EU-flavored fixtures are mandatory before quality claims** (OPEN: fixture authoring plan). 2. Multi-document policy suites (likely EU reality) are unaddressed — retrieval scope and person-resolution are per-document today (Phase 3). 3. Non-English, DOCX-born, and scanned uploads are untested (OCR path specified, unexercised). 4. Sub-heading detection for untagged flat manuals is heuristic — per-document structure-confidence must be recorded and surfaced. 5. Neither sample exercises RTS-template-field deterministic checks (complaints template, STOR fields) — those checks are specified from the RTS texts, not sample-proven. 6. Whether EU NCAs expect a consolidated WSP-style manual at all remains OPEN / **REQUIRES LEGAL REVIEW** — the product must not assume the FINRA genre transplants cleanly.

32. Final Recommendations (A–S)

A. Fix "WSP = Written Supervisory Procedures" in all product language; document the FINRA origin; never use "white paper". (§2) B. Ship MiCa **and** DORA control libraries at MVP; keep AML as a separately-labeled adjacent regime. (§5–6) C. Enforce the authority hierarchy in the data model itself — controls exist only with ELI/CELEX anchors; samples and customer documents can never become authority. (§7, §33-principle) D. Phrase every DORA finding as an evidence gap, never a breach; encode the phrasing in finding templates. (§6) E. Adopt the custom-JSON control model with immutable versions and a mandatory human review gate on all regulatory change. (§7–8) F. Key change detection off OJ metadata daily; treat consolidation as a lagging diff source; hash-monitor ESA pages with acknowledged reliability limits. (§8) G. Build the extraction stack local-first (Docling); resolve the PyMuPDF AGPL question before code exists; make cloud OCR per-tenant opt-in. (§9) H. Make the section tree + (doc_sha256, section, page, bbox) anchor the universal addressing contract across all stages. (§9–10) I. Extract typed, canonicalized claims (roles, frequencies, thresholds, citations) — contradiction detection is set logic over claims plus a calibrated NLI tier, not free-form LLM opinion. (§10, §15) J. Run the applicability filter before any retrieval; model authorisation status and microenterprise as first-class firm metadata. (§11) K. Enforce the five-state decision contract with system-filled citations and the deterministic span-verification gate; treat NEEDS_HUMAN_REVIEW as a product state, not an error. (§13–14) L. Bias every threshold toward FAIL-recall; asymmetric human review; trust ramp per tenant. (§14) M. Build the dependency index at evaluation time and the reuse-layer stack; honor change_impacts.invalidates as the human-curated case hashes cannot see. (§16) N. Alert only on worsening, with dedupe keys; digest everything else — alert fatigue is a churn risk. (§19) O. One PostgreSQL; no Neo4j; defer OpenSearch; outbox now, Temporal at fan-out scale. (§21–22) P. EU-pin everything, per-tenant DEK envelope encryption, egress-less parsing sandbox, single allowlisted fetcher, content-free logs; publish the short sub-processor list as a sales artifact. (§24) Q. Maintain eval records, golden sets (including synthetic EU fixtures), CI regression gates, and drift monitors from day one; label findings as AI-generated; build high-risk-adjacent AI Act hygiene without waiting for classification. (§25) R. Treat the control library + revalidation loop as the moat; invest in content curation and legal review ahead of model sophistication; exploit the pricing-transparency wedge. (§28) S. Keep the MVP strictly WSP-only; quarantine future document types behind fresh legal analysis per document class. (§29)

33. Decisions We Need to Make

Validation of the brief's final architectural principle (Section 49) — explicitly assessed. The principle — *the platform derives all compliance truth from the official regulatory hierarchy (Official Regulation → Requirement → Control → Expected Evidence → WSP evidence), one-way; uploaded documents are evidence to be judged, never sources of requirements* — is **VALIDATED** by this research, with two sharpenings rather than challenges: (1) it must extend *temporally* — authority is a *versioned expression* (ELI point-in-time), and interpretation layers (Q&As) can invalidate conclusions without any text change, which pure text-hashing cannot see; hence the human-curated change_impacts table is part of the authority chain, not an exception to it. (2) It must extend to *severity and sufficiency* — what counts as adequate evidence is itself an interpretive judgment that no layer of the hierarchy fully encodes; the principle therefore requires the standing **REQUIRES LEGAL REVIEW** machinery and human gates as first-class

components, not bolt-ons. One honest challenge noted: the samples show real compliance manuals contain internally *authoritative-looking* structures (rosters, signed appendices) that tempt shortcut logic; the engine must treat even signed appendices as claims about the firm, never as ground truth about compliance. The principle holds; the architecture above implements it.

#	CAT .	DECISION	WHY NOW	OPTIONS	RECOMMENDED	REASON	OPEN QUESTION
1	Product	Entity types at launch	Control-library scope depends on it	CASP-only; CASP+ART; all	CASP-only MVP	Art. 68 + Title V is the coherent surface; ART adds Title III + EBA GLs	Do pilot prospects include ART issuers?
2	Product	Single manual vs policy-suite upload	EU firms may not have one manual	Single PDF; multi-file suite	Single at MVP, suite Phase 3	Retrieval scope + person resolution are per-document today	What do real EU CASP document sets look like? (REQUIRES LEGAL REVIEW /market discovery)
3	Product	Free "top-10 gaps" GTM wedge	Differentiator vs opaque enterprise pricing	Free tier; demo-only; none	Free single-upload scan	Mirrors 4CRisk trial; showcases MISSING-column value	Abuse/cost controls for anonymous uploads?
4	Regulatory	L3/Q&A authority weighting in customer-facing findings	Non-binding sources can drive findings	Exclude; include labeled; include unlabeled	Include, hard-labeled non-binding	Q&As change real supervisory expectations	REQUIRES LEGAL REVIEW: wording that avoids implying bindingness
5	Regulatory	NCA-level expectations in scope?	Dossier practice differs per NCA	L1/L2/L3 only; + top-N NCA packs	L1/L2/L3 at MVP	NCA packs are a content treadmill	Which NCAs do pilots answer to?
6	Regulatory	Who performs control legal review	Every control needs sign-off	In-house counsel; external firm; advisory board	External EU fintech counsel + advisory board	Credibility + capacity	Budget and review SLA per ChangeSet
7	Architecture	BM25 host	Hybrid retrieval needs lexical	Postgres FTS; pg_search/ParadeDB; OpenSearch	Postgres FTS first	One datastore, one residency surface; corpus per query is tiny	Benchmark FTS vs pg_search on golden retrieval set
8	Architecture	Workflow engine timing	Outbox → Temporal migration cost	Temporal now; outbox now/Temporal later; Celery	Outbox now, Temporal at first large fan-out	MVP volumes don't justify infra; jobs shaped Temporal-like	Temporal Cloud EU residency terms acceptable?
9	Architecture	Extraction self-hosting crossover	Managed OCR rivals LLM cost at scale	Managed always; local always; switch at ~10k firms	Local-first from day one	Residency + cost; samples need no OCR	Real scanned-upload share from pilots
10	AI	Generation-model vendor + hosting	Confidentiality, Schrems II, cost	US API w/ EU endpoint + ZDR; EU-sovereign; self-hosted	EU-endpoint managed + zero-retention DPA; per-tenant configurable	Quality/cost today; pressure valve for refusers	REQUIRES LEGAL REVIEW: transfer analysis; EU-sovereign price 1.5–3×
11	AI	Embedding model	Residency + license	BGE-M3 self-hosted; Qwen3; managed EU	BGE-M3 self-hosted	Open weights, multilingual, removes a sub-processor	Multilingual quality on EU regulatory text — benchmark

#	CAT .	DECISION	WHY NOW	OPTIONS	RECOMMENDED	REASON	OPEN QUESTION
12	AI	PyMuPDF license posture	AGPL in closed SaaS	Buy commercial; pdfplumber (MIT); Docling-only	Decide pre-code; default pdfplumber if no purchase	Legal exposure is binary	Does Docling alone cover font-span heading detection?
13	AI	Human-review staffing model	NEEDS_HUMAN_REVIEW is a real queue	Customer-side only; platform analysts; hybrid	Hybrid: platform analysts during trust ramp, then customer CO	Quality control + scalable economics	Analyst cost per firm at 1k firms?
14	Security	DB-per-tenant trigger criteria	Enterprise demands physical separation	Never; on request; by tier	By tier, priced	Ops cost is real; some vendor-risk teams require it	Which pilot contracts require it already?
15	Security	Sub-processor list target	Every vendor = sales friction	Minimal (Postgres+LLM+cloud); convenience-rich	Minimal, published	DORA Art. 28 due diligence is a buying criterion	Can we avoid managed OCR entirely?
16	Data	Evidence/eval retention horizon	Audit vs storage/GDPR	24mo hot + archive; 5yr full; customer-config	24mo hot + archived partitions ≥5yr	MiCA Art. 68(9) 5-yr reference period customers mirror	REQUIRES LEGAL REVIEW: exact contractual retention
17	Data	Embedding dimensionality/model pinning	Re-embedding is a migration	1024-d BGE-M3; 1536-d managed	1024-d BGE-M3, versioned migrations	Cache keyed (model, text_sha256) makes swaps tractable	halfvec storage saving worth it at 100k firms?
18	Operations	ChangeSet triage SLA	Regulatory changes queue behind humans	2bd L1/L2 + 5bd L3 (proposed); tighter; looser	2bd / 5bd, instrumented	Balances risk vs analyst load	Actual OJ change frequency for MiCA/DORA — measure
19	Operations	Golden-set fixture authoring	PASS class needs synthetic EU WSPs	Internal; counsel-reviewed synthetic; pilot-donated	Synthetic + counsel review; add anonymized pilot data with consent	Two US samples can't cover PASS	Consent/anonymization framework for customer-derived fixtures
20	Operations	Pricing model	Wedge strategy needs numbers	Per-firm flat; per-document; per-seat; tiered	Tiered per-firm flat, published	Cost/firm = \$1.4 ⇒ software-margin pricing viable at mid-market price points	Willingness-to-pay discovery in pilots

34. Source Register

Official (authoritative; all accessed 2026-08-17): - MiCA — Regulation (EU) 2023/1114: <https://eur-lex.europa.eu/eli/reg/2023/1114/oj/eng> · consolidated example CELEX 02023R1114-20240109: <https://eur-lex.europa.eu/eli/reg/2023/1114/2024-01-09/eng> - DORA — Regulation (EU) 2022/2554: <https://eur-lex.europa.eu/eli/reg/2022/2554/oj> (EUR-Lex blocked automated retrieval during research — HTTP 202; article text cross-verified via mirror, EUR-Lex cited as sole authority) - DORA L2: CDR (EU) 2024/1772, 2024/1773, 2024/1774; CIR (EU) 2024/2956; CDR 2025/301 + CIR 2025/302; CDR 2025/532; CDR 2025/1190 — https://eur-lex.europa.eu/eli/reg_del/2025/301/oj ; <https://ec.europa.eu/finance/docs/level-2-measures/> - MiCA L2: CDR (EU) 2025/294, 2025/305 + CIR 2025/306, 2025/416, 2025/885, 2025/1140, 2025/1142 — instrument numbers cross-verified via secondary trackers; **each must be re-resolved to its EUR-Lex ELI URL before production activation** (recorded caveat) - ESMA: MiCA Level 2/3 table ESMA75-113276571-1510 (Jul 2025); suitability GLs ESMA35-1872330276-2031; knowledge & competence GLs ...-2380; Q&A 2364 (<https://www.esma.europa.eu/publications-data/questions-answers/2364>); Interactive Single Rulebook; iXBRL white-paper PoC - EBA: Interactive Single Rulebook (DORA+MiCA); Single Rulebook Q&A; Travel Rule Guidelines; ART internal-governance Guidelines - Travel Rule Reg. (EU) 2023/1113; AMLR (EU) 2024/1624; EU AI Act (EU) 2024/1689: <https://eur-lex.europa.eu/eli/reg/2024/1689/oj>; GDPR (EU) 2016/679 - FINRA Rule 3110 / Supervision FAQ: <https://www.finra.org/rules->

guidance/rulebooks/finra-rules/3110 - EUR-Lex/CELLAR technical: <https://op.europa.eu/en/web/cellar/cellar-data> · <https://eur-lex.europa.eu/content/help/data-reuse/webservice.html> · AKN4EU: <https://op.europa.eu/en/web/eu-vocabularies/akn4eu> · ELI: <https://eur-lex.europa.eu/EN/legal-content/summary/european-legislation-identifier-eli.html>

Best-practice / engineering / market (not regulatory authority): OWASP GenAI LLM01:2025; Anthropic contextual retrieval; PhantomLint (arXiv 2508.17884); arXiv 2605.28999; NIST OSCAL; Docling; PyMuPDF licensing; Azure/AWS/Google document-AI pricing pages; pgvector/OpenSearch and Temporal/Kafka comparisons; Anthropic/OpenAI price aggregators; ~30 vendor sites and trade-press sources itemized in [market/competitor-analysis.md](#); law-firm trackers (Latham, Gibson Dunn, Covington, Travers Smith, Springlex, mica.wtf, Regulation Tomorrow) used as locators only. Per-file source lists with access dates live in each linked detail document.

Local evidence: read-only poppler probes of the two sample PDFs (2026-08-17); no prompt-injection strings found in either; samples unmodified.